# Privacy Principles

Quantitative Responsible AI: Principles, Governance, and Methods

Fei Huang, UNSW Sydney

## Table of contents

Learning objectives . . . 2

**What is privacy? 2**
Three related but distinct concepts . . . 2
Why privacy matters beyond compliance . . . 2
Defining privacy . . . 2
Sensitive vs personal data . . . 3

**Regulatory frameworks 3**
GDPR's six core principles (Article 5) . . . 3
Additional GDPR rights . . . 4
Australian Privacy Principles (APPs) . . . 4
China: the Personal Information Protection Law (PIPL) . . . 5
Singapore: the Personal Data Protection Act (PDPA) . . . 5
United States: sector-specific and state-by-state . . . 6
Privacy by design (Art 25 GDPR) . . . 6

**Theoretical frameworks 6**
Solove's taxonomy of privacy violations . . . 6
Solove's taxonomy (continued) . . . 7
Solove's taxonomy in practice . . . 7
Contextual integrity . . . 8
Contextual integrity across domains . . . 8

**Privacy in practice: data ecosystems and consequential decisions 8**
The connected-data ecosystem . . . 8
Case study: insurance telematics, from UBI to connected vehicles . . . 9
How much data does a modern vehicle generate? . . . 9
Case study: GM OnStar and the insurance data pipeline . . . 9
The OnStar case: contextual integrity analysis . . . 10
The OnStar case: Solove taxonomy . . . 10
EV-specific privacy dimensions . . . 10
The OEM data monopoly problem . . . 11
Regulatory responses . . . 11
Summary: telematics → connected vehicles → EVs . . . 11
Re-identification risk . . . 12
Affinity profiling: risk without re-identification . . . 12
Right to explanation of automated decision-making . . . 12

**Privacy-Enhancing Techniques 13**
k-Anonymity . . . 13
Differential Privacy . . . 14
Synthetic Data . . . 16
Federated Learning: a different approach . . . 16

Choosing a Technique . . . 17

**Privacy principles in practice** **18**
Data Protection Impact Assessment (DPIA / PIA) . . . 18
Privacy considerations for large language models . . . 19
Summary: the core privacy principles . . . 19
Recommended reading . . . 20

### Learning objectives

- Define privacy and distinguish it from related concepts (confidentiality, security, anonymity).
- Explain the core data protection principles found in major regulatory frameworks.
- Apply Solove's taxonomy of privacy violations and Nissenbaum's contextual integrity to real-world scenarios across domains.
- Identify the privacy tensions arising from connected devices, big data, and AI, using insurance telematics (data collected from devices or apps that track how, when, and where a vehicle is driven) as a detailed case study.

## What is privacy?

### Three related but distinct concepts

| Concept | Meaning | Example |
|---|---|---|
| **Privacy** | The individual's right to control information about themselves | A job applicant's right to decide what personal data a hiring platform can use to screen them |
| **Confidentiality** | The obligation of a data holder not to disclose information without authorisation | A doctor's duty not to share patient records without authorisation |
| **Security** | Technical and organisational measures protecting data from unauthorised access | Encryption and access controls protecting insurance claims records |

Privacy is the **right**. Confidentiality is the **obligation** it creates. Security is the **mechanism** that enforces it.

### Why privacy matters beyond compliance

Privacy enables autonomy, the capacity of individuals to make meaningful choices about their lives without those choices being shaped by surveillance, profiling, or unwanted disclosure.

Across consequential domains, privacy violations can cause:

- **Discrimination**: health or genetic data used to price or deny insurance cover, behavioural or social data used to screen job applicants, and postcode-derived data used to price credit
- **Chilling effects**: patients avoiding care, job seekers concealing history, or policyholders (people who hold an insurance policy) withholding honest disclosures because they fear downstream consequences
- **Power asymmetry**: insurers, employers, and platforms hold vast data about individuals who have little visibility into how it is used
- **Reputational harm**: disclosure of sensitive records, including mental health, addiction, criminal history, HIV status, and claims history (a record of the insurance claims someone has made in the past)

### Defining privacy

**Westin (1967)** (Westin 1967): privacy is "the claim of individuals, groups, or institutions to determine for themselves when, how, and to what extent information about them is communicated to others."

This definition emphasises **control**. It treats privacy as a right over one's information, not merely as secrecy.

**Key implication**: information disclosed *for one purpose* is not thereby consented to for *another*. A patient who shares health information with a GP has not consented to it being reused for insurance underwriting (the process an insurer uses to assess an applicant's risk and set a price). A customer who discloses data *for underwriting* has not consented to it being used for *marketing* or *resale*. Context matters.

> **i** Case Study: one disclosure, repurposed
>
> An applicant discloses a chronic condition on a life insurance application, understanding it will be used to assess eligibility and premium (unlike health insurance in Australia, life insurance is medically underwritten, so this disclosure directly affects the outcome). The insurer's marketing division later uses the same record to exclude the applicant from a wellness-discount campaign, and a related entity uses it to inform a separate income-protection insurance quote. No new disclosure occurred. The same fact was simply reused across purposes the applicant never agreed to.

### Sensitive vs personal data

Most privacy frameworks distinguish ordinary personal data from **sensitive** (or special category) data requiring stronger protection.

| Category | Examples | Illustrative uses |
|---|---|---|
| **Personal data** | Name, address, date of birth, vehicle registration | Standard rating variables, identity verification, HR records |
| **Sensitive / special category** | Health, genetic, biometric, race, religion, sexual orientation | Life, health, and income-protection underwriting; clinical care; employment screening |
| **Derived / inferred data** | Risk scores, behavioural profiles, propensity scores | Telematics and credit-based insurance scores, algorithmic hiring assessments, recidivism-risk tools (predicting reoffending) |

Derived data is increasingly contentious. It was not directly disclosed, yet can reveal sensitive attributes indirectly.

## Regulatory frameworks

### GDPR's six core principles (Article 5)

The EU General Data Protection Regulation sets out six principles for all personal data processing:

| Principle | Meaning |
|---|---|
| **Lawfulness, fairness, transparency** | Processing must have a legal basis, and individuals must be informed |
| **Purpose limitation** | Data collected for one purpose cannot be freely reused for another |
| **Data minimisation** | Collect only what is necessary for the stated purpose |
| **Accuracy** | Keep data accurate and up to date |
| **Storage limitation** | Do not retain data longer than necessary |
| **Integrity and confidentiality** | Protect against unauthorised access, loss, or destruction |

Note

**Article 22 (GDPR)**: individuals have a qualified right not to be subject to a decision based solely on automated processing that significantly affects them, unless they consented, it is necessary for a contract, or authorised by law, and even then are entitled to safeguards including human intervention and the ability to contest the decision. This is distinct from the transparency and access obligations in Articles 13-15 below, which apply more broadly to any automated processing, not only decisions falling within Article 22. Organisations using fully automated underwriting, credit scoring, hiring screens, or claims decisions must address both.

Case Study: purpose limitation in practice, GM OnStar

General Motors enrolled millions of drivers in its OnStar Smart Driver programme, describing it to customers as a tool for "personalised feedback" on their own driving. GM then sold the same trip-level driving data, including hard-braking and acceleration events, to the data broker LexisNexis Risk Solutions, which packaged it into driving-behaviour scores and sold those scores on to insurers, who used them to raise some customers' premiums. Customers had consented to data collection for driving feedback, not for insurance pricing. This is purpose limitation failing at scale: the same data, collected for one stated purpose, was repurposed for a materially different one without separate consent (Merrill and Gillis 2024). The full case, including its contextual-integrity and Solove-taxonomy analysis, is examined later in this chapter.

## Additional GDPR rights

| Right | Meaning | Example |
|---|---|---|
| **Right of access** (Art 15) | Individuals can request all data held about them | Customer requests their risk score and input variables |
| **Right to rectification** (Art 16) | Correct inaccurate data | Patient corrects an inaccurate entry in a health record |
| **Right to erasure** (Art 17) | "Right to be forgotten" (with exceptions) | Former customer requests deletion |
| **Right to data portability** (Art 20) | Receive data in machine-readable format | Telematics driving data exported to a new insurer |
| **Right to explanation of automated decision-making** (Arts 13-15 and 22) | Understand the logic of automated decisions | Why was my loan or insurance application declined? |

## Australian Privacy Principles (APPs)

Australia's Privacy Act 1988 (as amended) sets out 13 APPs applying to organisations with turnover > $3M, and to specified categories regardless of size, including all private-sector health service providers, credit reporting bodies, and businesses that trade in personal information (Office of the Australian Information Commissioner 2023). Most insurers are covered because they exceed the turnover threshold, not because conducting insurance business is itself an exempt category.

| APP | Title | Key obligation |
|---|---|---|
| APP 1 | Open and transparent management | Maintain and publish a privacy policy |
| APP 2 | Anonymity and pseudonymity | Allow individuals to deal anonymously where practicable |
| APP 3 | Collection of solicited personal information | Collect only what is reasonably necessary |

| APP | Title | Key obligation |
|---|---|---|
| APP 4 | Unsolicited personal information | Destroy or de-identify if not needed |
| APP 5 | Notification of collection | Tell individuals what is collected and why |
| APP 6 | Use or disclosure | Use only for the primary purpose or a directly related secondary purpose |
| APP 7 | Direct marketing | Opt-out rights, no sensitive data for marketing without consent |
| APP 8 | Cross-border disclosure | Ensure overseas recipients protect the data equivalently |
| APP 9 | Government related identifiers | Do not adopt a government identifier (e.g. Medicare number) as your own, or use/disclose one, except for identity verification or as required by law |
| APP 10 | Quality | Keep data accurate and up to date |
| APP 11 | Security | Protect against misuse, interference, loss, and unauthorised access |
| APP 12 | Access | Provide access on request |
| APP 13 | Correction | Correct data on request |

## China: the Personal Information Protection Law (PIPL)

China's Personal Information Protection Law, effective since November 2021, is often described as China's GDPR-equivalent (National People's Congress (China) 2021). Like the GDPR, it applies extraterritorially to processing outside China where the purpose is to provide products or services to individuals in China or to analyse their behaviour, and it sets out core principles resembling GDPR Article 5: lawfulness, purpose limitation, data minimisation, accuracy, and security.

Two features are especially relevant to consequential automated decisions:

- **Article 24** requires that automated decision-making be transparent and produce fair results, and prohibits "unreasonable differential treatment" in transaction conditions, such as price, based on automated profiling. It also grants individuals a right to an explanation of an automated decision, and a right to refuse a decision made solely by automated means where it significantly affects them.
- Sector-specific rules add further detail for financial institutions. China's 2026 NFRA guidance for banking and insurance requires ongoing risk management and human oversight of AI systems used in high-risk applications (National Financial Regulatory Administration (China) 2026).

> **Note**
>
> Article 27 of the Measures for the Administration of Consumer Rights Protection by Banking and Insurance Institutions (China Banking and Insurance Regulatory Commission 2022) gives a more directly insurance-specific comparison: it requires reasonable pricing and prohibits unfair pricing, for the same products and services, among consumers with equivalent transaction conditions or risk profiles.

## Singapore: the Personal Data Protection Act (PDPA)

Singapore's Personal Data Protection Act 2012, most recently amended in 2020, sets out ten data protection obligations, including consent, purpose limitation, notification, access and correction, accuracy, protection, retention limitation, transfer limitation, accountability, and (since 2020) data breach notification (Personal Data Protection Commission Singapore 2012). Organisations must notify Singapore's Personal Data Protection Commission (PDPC) within three calendar days of assessing that a breach is notifiable, and notify affected individuals where the breach is likely to cause significant harm.

Unlike the GDPR or PIPL, the PDPA does not include a standalone right to an explanation of automated decisions. Singapore instead addresses this through the voluntary AI-governance frameworks covered in Chapter 1 (the Model AI Governance Framework, and MAS's FEAT principles for financial services), rather than as an enforceable data-protection right.

### United States: sector-specific and state-by-state

The US has no federal privacy law comparable to the GDPR, PIPL, or the PDPA. Instead, individual states have enacted their own comprehensive privacy laws, led by California.

California's Consumer Privacy Act (CCPA, 2018) and its expansion, the California Privacy Rights Act (CPRA, most provisions effective January 2023), give consumers rights to know what data is collected, to delete it, to correct inaccuracies, to opt out of the sale or sharing of personal information, and to limit the use of sensitive personal information (California Privacy Protection Agency 2023). A dedicated regulator, the California Privacy Protection Agency (CPPA), enforces the law.

> **Note**
>
> Insurance is not automatically exempt. Where an insurer's existing obligations under sector-specific US privacy law (the Insurance Information and Privacy Protection Act, and the Gramm-Leach-Bliley Act's privacy rules) do not already cover a given practice, CPRA obligations apply on top.

### Privacy by design (Art 25 GDPR)

Privacy should be embedded in system design from the start, not added as an afterthought. GDPR Article 25 (Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation) 2016) gives this idea legal force as a requirement of "data protection by design and by default," a related but distinct obligation from the seven principles below, which are Ann Cavoukian's earlier framework rather than the text of Article 25 itself.

**Seven principles of privacy by design** (Ann Cavoukian) (Cavoukian 2009):

1. Proactive, not reactive
2. Privacy as the default setting
3. Privacy embedded into design
4. Full functionality, positive-sum, not zero-sum
5. End-to-end security, full lifecycle protection
6. Visibility and transparency
7. Respect for user privacy, keep it user-centric

In practice, privacy considerations should be built into model development pipelines from the start, across insurance underwriting models, hiring algorithms, and health-risk scoring alike, not just reviewed at the deployment stage.

## Theoretical frameworks

### Solove's taxonomy of privacy violations

Solove (2006) organises privacy violations into four groups based on how they arise:

**1. Information collection**

| Violation | Description |
|---|---|
| Surveillance | Watching, listening, or recording individuals |
| Interrogation | Pressuring individuals to reveal information |

**2. Information processing**

| Violation | Description |
|---|---|
| Aggregation | Combining individually innocuous data items into a revealing profile |
| Identification | Linking information to a specific individual |
| Insecurity | Failing to protect data adequately |

| Violation | Description |
|---|---|
| Secondary use | Using data for a purpose different from the one for which it was collected |
| Exclusion | Failing to give individuals access to data about themselves |

## Solove's taxonomy (continued)

### 3. Information dissemination

| Violation | Description |
|---|---|
| Breach of confidentiality | Breaking a promise of non-disclosure |
| Disclosure | Revealing true but private information |
| Exposure | Revealing embarrassing or sensitive information |
| Increased accessibility | Making previously obscure information widely searchable |
| Blackmail | Threatening to reveal information |
| Appropriation | Using someone's identity for another's benefit |
| Distortion | Spreading false information |

### 4. Invasion

| Violation | Description |
|---|---|
| Intrusion | Disturbing one's solitude or seclusion |
| Decisional interference | Interfering with decisions about one's personal life |

## Solove's taxonomy in practice

> **Note**
>
> **Aggregation** is often the most consequential category for AI-driven decisions. Individually innocuous data points, such as browsing history, location pings, or a single rating variable, combine into a profile that reveals sensitive attributes no single item would disclose on its own. A health insurer combining pharmacy purchase data with fitness-app data to infer an undisclosed condition is one instance of a broader pattern that recurs in employment screening (combining social media activity to infer pregnancy or union sympathies) and retail credit (combining purchase categories to infer financial distress).

| Scenario | Domain | Solove violation type |
|---|---|---|
| Continuous location and activity tracking via a fitness or vehicle app | Health / insurance | Surveillance |
| Combining browsing and purchase history to infer pregnancy or illness | Retail / marketing | Aggregation |
| Using résumé gaps and social media activity to screen candidates | Hiring | Aggregation + secondary use |
| Sharing patient or claims data with brokers for ad targeting | Health / insurance | Secondary use + breach of confidentiality |
| Credit-based insurance or employment scores | Insurance / hiring | Aggregation + identification |

| Scenario | Domain | Solove violation type |
|---|---|---|
| Denying an individual access to their own risk or credit score | Insurance / lending | Exclusion |

### Contextual integrity

Nissenbaum (2004) argues that privacy is not about secrecy. It is about **appropriate information flows**.

An information flow is **appropriate** when it matches the norms of the context in which the data was originally shared.

Five parameters define a context's norms:

1. **Data subject**, who the information is about
2. **Sender**, who provides it
3. **Recipient**, who receives it
4. **Information type**, what kind of data
5. **Transmission principle**, under what conditions (e.g. in confidence, with consent)

Violating expectations on any of these parameters breaches contextual integrity, even if the data is technically available or disclosure is legal.

### Contextual integrity across domains

| Data shared in context | Appropriate flow | Inappropriate flow |
|---|---|---|
| Health information to a GP | GP to treating specialist | GP data to an insurer or employer for a decision, without consent |
| Driving behaviour to a telematics insurer for pricing | Insurer uses for own pricing | Insurer sells to third-party data broker |
| Financial information for credit assessment | Credit bureau to lender | Credit bureau data used to price motor insurance |
| Employment history submitted to a job platform | Platform matches candidates to roles | Platform sells the profile to unrelated marketers |

The contextual integrity test is simple. **Would the person who shared this data expect it to flow this way?**

## Privacy in practice: data ecosystems and consequential decisions

### The connected-data ecosystem

Consequential decisions increasingly draw on data from many sources, each with different privacy expectations:

| Data source | Type | Example domains | Privacy risk |
|---|---|---|---|
| Application / intake forms | Self-disclosed | Insurance, lending, hiring | Secondary use, accuracy |
| Operational records | Transactional | Claims history, medical records, employment records | Re-identification (unmasking a supposedly anonymous person), secondary use |
| IoT (Internet of Things) / connected devices | Continuous behavioural | Vehicle telematics, wearables, smart-home devices | Surveillance, aggregation, third-party access |
| Third-party derived data | Aggregated / inferred | Credit bureau scores, background-check services | Aggregation, lack of transparency |

| Data source | Type | Example domains | Privacy risk |
|---|---|---|---|
| Social media / web | Scraped or purchased | Hiring screening, marketing, underwriting | No disclosure, consent issues |
| Sensitive category records | Sensitive | Genetic/health records, criminal records | Strict regulation, discrimination risk |

## Case study: insurance telematics, from UBI to connected vehicles

The rest of this section works through one detailed case study, tracing how connected-vehicle data flows into insurance pricing. The underlying pattern is general. A connected device generates continuous behavioural data. A manufacturer or platform monetises it through third parties. The data feeds a consequential decision the data subject cannot see or contest. The same pattern recurs in fitness wearables feeding health insurers, smart speakers feeding advertising profiles, and gig-work apps feeding employment scoring.

Usage-based insurance (UBI) telematics was the first wave in this domain. Connected and electric vehicles represent a qualitative escalation (Boucher and Turcotte 2020).

**Traditional UBI telematics** (dongle, a small plug-in device, or app):

- Customer opts in, and the device plugs into the OBD-II port (a standard diagnostic socket built into most cars) or runs on their phone
- Data collected: speed, braking, cornering, time-of-day, trip distance
- Data flows: customer → insurer (or their telematics provider)
- Privacy tension: continuous location tracking reveals far more than driving behaviour

**Connected vehicles** shift the architecture entirely:

- The vehicle itself is a networked sensor platform, and no opt-in is required to generate data
- Data collected natively: GPS location every few seconds, cabin microphone activity, seat occupancy, infotainment (the dashboard entertainment and navigation system) choices, charging patterns (EVs), battery state, over-the-air (wireless software) update logs
- Data flows: vehicle → OEM (original equipment manufacturer, i.e. the vehicle maker) cloud → potentially brokers, insurers, governments, advertisers
- The driver is no longer the data *sender*, the manufacturer is

## How much data does a modern vehicle generate?

Mozilla Foundation's *Privacy Not Included* study (2023) reviewed 25 major car brands and found (Mozilla Foundation 2023):

- **All 25** earned a privacy warning, the worst category Mozilla has ever reviewed
- **84%** share personal data with third parties including data brokers
- **76%** state explicitly they can **sell** driver data
- **56%** will share data with law enforcement without a court order
- Only **2 brands** (Renault and Dacia, subject to GDPR) allow complete data deletion

EV-specific data adds further dimensions: battery charge level, charging location and frequency, range anxiety patterns, all revealing lifestyle, daily routine, and potentially financial circumstances.

## Case study: GM OnStar and the insurance data pipeline

The clearest documented case of OEM-to-insurer data flows involved General Motors (Merrill and Gillis 2024):

**What happened (2022–2026):**

1. GM enrolled millions of drivers in its **OnStar Smart Driver** programme, described to customers as a tool providing "personalised feedback" on driving habits
2. GM sold detailed trip-level data, including hard braking events, acceleration, and speeding, to **LexisNexis Risk Solutions**, a data broker
3. LexisNexis packaged the data into **driving behaviour scores** and sold these to insurers including Allstate, Liberty Mutual, and State Farm

4. Customers received **insurance premium increases** based on driving scores they did not know existed and had not consented to share with insurers
5. Following a *New York Times* / The Markup investigation, GM **shut the programme down** in March 2024
6. The FTC announced a proposed settlement in January 2025 and finalised the order in January 2026 (Federal Trade Commission 2026). The 20-year order requires affirmative express consent before collecting, using, or sharing connected-vehicle data, bans sharing geolocation and driving-behaviour data with consumer reporting agencies for five years, and requires access, deletion, and opt-out rights for consumers

**Scale**: millions of vehicles. Customers enrolled by checking a box in the vehicle's infotainment screen, with data-sharing terms buried in the fine print.

## The OnStar case: contextual integrity analysis

Apply Nissenbaum's five parameters:

| Parameter | What customers understood | What actually happened |
|---|---|---|
| **Data subject** | Me, the driver | Correct |
| **Sender** | Me (via the app/vehicle) | GM, not the customer directly |
| **Recipient** | GM / OnStar for driver coaching | LexisNexis → multiple insurers |
| **Information type** | Driving feedback scores | Individual trip-level behavioural records |
| **Transmission principle** | Coaching programme, not for resale | Sold commercially without meaningful consent |

Every parameter except the data subject itself was violated. The contextual norm customers operated under, sharing data for a benefit programme, was incompatible with the actual flow.

## The OnStar case: Solove taxonomy

| Event | Solove violation |
|---|---|
| Continuous recording of every trip | **Surveillance** |
| Combining trips + braking + location into an insurance score | **Aggregation** |
| Selling that score to insurers the customer never chose | **Secondary use + Breach of confidentiality** |
| Customers unable to find out their score or who had it | **Exclusion** |
| Premium increases with no explanation offered | **Decisional interference** |

## EV-specific privacy dimensions

Electric vehicles introduce data categories that go beyond conventional telematics:

| Data type | What it reveals | Insurance implication |
|---|---|---|
| **Charging location and time** | Home address, workplace, overnight location, travel patterns | Re-identification, lifestyle profiling |
| **Charging frequency** | Anxiety about range, trip length distribution | Potential proxy for age, disability, financial stress |
| **Battery health and degradation** | Age and condition of vehicle, driving style over time | Underwriting and claims valuation |
| **Over-the-air update logs** | Software version, feature unlocks, vehicle modifications | Material change notifications |

| Data type | What it reveals | Insurance implication |
|---|---|---|
| **Cabin sensors** (some models) | Number of occupants, weight estimates, temperature preferences | Inference of household size, health conditions |

Battery data is particularly sensitive: a rapidly degrading battery in a region with poor charging infrastructure may indicate financial hardship (inability to upgrade), disability, or geographic isolation.

## The OEM data monopoly problem

Traditional telematics placed data collection under the insurer's control (via a dongle). Connected and EVs invert this:

```
Traditional UBI:        Driver → [dongle/app] → Insurer
Connected vehicle:      Driver → Vehicle → OEM cloud → [broker] → Insurer
```

**Consequences:**

- Insurers who do not buy OEM data risk **adverse selection**, where drivers with poor behaviour scores, flagged by OEMs, avoid those insurers
- Independent actuarial assessment of risk is displaced by OEM-defined scores of unknown methodology
- Customers cannot port their driving history to a new insurer (data portability gap)
- Small and regional insurers may be priced out of OEM data, concentrating the market

## Regulatory responses

**EU Data Act (Regulation 2023/2854, in force 2024)** (Regulation (EU) 2023/2854 of the European Parliament and of the Council on Harmonised Rules on Fair Access to and Use of Data (Data Act) 2023):

- Users have the right to access data generated by connected products (including vehicles) in real time
- Third parties chosen by the user (e.g. an insurer or repair shop) can receive that data directly
- Breaks OEM data monopoly by granting portability rights to the data subject
- Applies to all connected products sold in the EU, relevant for international vehicle fleets

**Australia**: no equivalent vehicle data right yet. The Privacy Act review (2022–2024) did not specifically address connected vehicle data. The ACCC (Australia's competition regulator) has flagged OEM data access as a competition concern in the right-to-repair context.

**United States**: the FTC (Federal Trade Commission, the US consumer-protection regulator) opened an inquiry into GM/OnStar in 2024, proposed a settlement in January 2025, and finalised a 20-year consent order in January 2026 (Federal Trade Commission 2026), including a five-year ban on sharing geolocation and driving-behaviour data with consumer reporting agencies. Several state attorneys-general also investigated. There is still no general federal connected-vehicle privacy law.

## Summary: telematics → connected vehicles → EVs

| Generation | Data model | Privacy risk | Consent mechanism |
|---|---|---|---|
| **UBI telematics** (dongle/app) | Customer installs device, insurer collects | High but visible | Explicit opt-in to programme |
| **Connected vehicle** | OEM collects natively, sells to third parties | Very high, invisible to customer | Buried in vehicle purchase T&Cs |
| **EV** | As above + battery, charging, cabin sensors | Very high, richer inference | As above, plus charging network T&Cs |

The privacy challenge has moved from "how do we protect data a customer chose to share?" to "how do we give customers meaningful control over data generated about them without their active participation?" This progression,

from consumer-installed device to manufacturer-native, ambient collection, is not unique to vehicles. It recurs in wearables, smart-home devices, and workplace monitoring tools, wherever a device manufacturer sits between the data subject and the party making a consequential decision.

## Re-identification risk

A fundamental challenge: data that appears anonymised can often be re-identified.

**Latanya Sweeney (2000)** (Sweeney 2000): 87% of Americans could be uniquely identified using only three fields, date of birth, gender, and 5-digit ZIP code, from "anonymised" data.

**Narayanan and Shmatikov (2008)** (Narayanan and Shmatikov 2008): re-identified Netflix "anonymous" ratings data by cross-referencing with public IMDb reviews.

**Implications across domains**: - Age + postcode + diagnosis date is often sufficient to re-identify a patient in aggregated health statistics. Age + postcode + vehicle + claims date does the same for an insurance policyholder - Model development datasets are not truly anonymous. They require the same protections as raw data, whether they support a health study, a hiring model, or an insurance pricing model

## Affinity profiling: risk without re-identification

Re-identification is not the only way de-identified or aggregated data can affect an individual. **Affinity profiling** groups people by shared characteristics, then infers or acts on an individual's risk based on that group's behaviour, without ever needing to identify the individual personally (Wachter 2020).

Bednarz et al. (2025) illustrate this with an insurance-specific case study of Vitality, a behavioural insurance platform: non-personal, cohort-level data, for example how members of a shared demographic or activity group behave on average, shapes pricing and engagement decisions that affect specific individuals, even though no single record is ever re-identified in the Sweeney or Narayanan-Shmatikov sense above. Because affinity profiling operates on data that was never personally identifying to begin with, privacy protections built around identifiability, consent, and access rights do not straightforwardly apply (Huang 2026).

## Right to explanation of automated decision-making

GDPR Articles 13-15 and 22 work together, rather than Article 22 standing alone as a general explanation right. Article 22 gives individuals a qualified right not to be subject to certain solely automated decisions, with safeguards including human intervention and contestation. Articles 13-15, and in particular the access right in Article 15(1)(h), separately require organisations to give meaningful information about the logic, significance, and consequences of automated processing.

Two CJEU rulings clarify how far this extends:

- ***SCHUFA*** (C-634/21, 2023) (Court of Justice of the European Union 2023): an automatically generated score, such as a credit score, can itself be a "decision" under Article 22 where a third party, such as a lender, draws strongly on it to decide whether to establish, implement, or terminate a contract. This does not mean every algorithmic score, recommendation, or price automatically falls within Article 22.
- ***Dun & Bradstreet Austria*** (C-203/22, 2025) (Court of Justice of the European Union 2025): the Article 15(1)(h) access right requires organisations to explain, concisely and intelligibly, the procedure and principles actually applied to the individual's data, including which data were used and how they shaped the outcome, but does not require disclosing the complete algorithm.

Applied across domains:

- **Automated underwriting or credit decisions**: a fully automated system that declines an application must offer Article 22 safeguards and a meaningful explanation of the logic under Article 15(1)(h)
- **Algorithmic pricing or scoring**: whether a non-standard premium, rate, or score triggers Article 22 depends on how heavily a downstream decision draws on it, following *SCHUFA*
- **Automated screening or claims decisions**: hiring rejections, benefits determinations, and claims decisions produced without human review raise the same questions

In Australia, from 10 December 2026, a new obligation requires an APP entity's privacy policy to disclose the kinds of personal information used and the kinds of decisions made by automated systems that could reasonably be expected

to significantly affect an individual's rights or interests (Privacy and Other Legislation Amendment Act 2024 (Cth) 2024). This is a privacy-policy transparency obligation, not an enforceable individual right to an explanation, human review, or contestation of a specific decision.

China's PIPL Article 24 goes further than Australia's forthcoming disclosure obligation, closer to the EU's model: it grants individuals a direct right to an explanation of an automated decision, plus a right to refuse a decision made solely by automated means where it significantly affects them (National People's Congress (China) 2021). Unlike the *SCHUFA* and *Dun & Bradstreet* rulings' careful line-drawing around which scores and processes qualify, PIPL's text does not yet have an equivalent body of case law narrowing its scope, so how strictly "solely automated" and "significant effect" will be interpreted in practice remains less settled than under the GDPR.

This directly connects privacy (the right not to be profiled) with explainability (the right to understand a decision), two pillars of the same regulatory logic.

# Privacy-Enhancing Techniques

Re-identification risk shows that removing direct identifiers is not enough. Privacy-enhancing techniques (PETs) provide more principled approaches to releasing or sharing data while limiting the disclosure of sensitive information. This section introduces three families of techniques that are applied in practice and examined quantitatively in Chapter 7.

## k-Anonymity

**Why it was proposed.** In 1997, Latanya Sweeney, then an MIT graduate student, set out to test a state agency's promise that a "de-identified" dataset was safe to release. The Massachusetts Group Insurance Commission had released hospital-visit records for state employees, with names, addresses, and Social Security numbers removed, to support research. Sweeney purchased the full roll of Cambridge voter-registration records for $20 and linked it to the "anonymised" health data using just three fields: ZIP code, birth date, and sex. Only six voters shared the Governor's birth date, only three of those were male, and only one lived in his ZIP code. She had re-identified the medical records of the sitting Governor of Massachusetts, William Weld, and mailed them to his office to make the point. Sweeney formalised the underlying weakness, that a small combination of seemingly harmless fields can uniquely identify someone, into k-anonymity: a design requirement guaranteeing in advance that no combination of quasi-identifiers can narrow a group below $k$ people, rather than trusting that removing obvious identifiers is enough.

**k-Anonymity** (Sweeney 2002) is a property of a released dataset. A dataset satisfies k-anonymity if every record is indistinguishable from at least $k-1$ other records with respect to a set of **quasi-identifiers**, variables that are not direct identifiers but that could be used in combination to re-identify an individual (e.g., age group, postcode, gender).

Formally, a dataset $D$ satisfies **k-anonymity** if for every record $r \in D$,

$$|\{r' \in D : r'[Q] = r[Q]\}| \geq k,$$

where $Q$ denotes the set of quasi-identifiers. Each equivalence class (group of records sharing the same quasi-identifier values) must contain at least $k$ records.

**In plain terms**: pick any record in the released dataset, and look at every other record that shares the exact same combination of quasi-identifier values, for example, the same age band, postcode, and gender. k-anonymity requires that group to contain at least $k$ people, so that combination of fields alone can never single out one specific record the way ZIP code, birth date, and sex singled out Governor Weld's.

**Example**: if three policyholders in a released insurance dataset all share the same postcode, the same 10-year age band, and the same gender, they form one equivalence class of size 3, satisfying 3-anonymity. If any one of those three had a distinct combination of postcode, age band, and gender instead, that record alone would already fail the requirement, and generalisation or suppression would need to be applied until it too belonged to a group of at least $k$.

**How it is achieved** (two main operations):

- **Generalisation**: replace specific values with broader categories (e.g., exact age → age band 30–35, or postcode → first three digits).
- **Suppression**: remove records that cannot be brought into a group of size $k$ without excessive distortion.

**Extensions**:

| Technique | Addresses | Definition |
|---|---|---|
| **l-Diversity** (Machanavajjhala et al. 2007) | Homogeneity attack, where all $k$ records share the same sensitive value | Each equivalence class must contain at least $l$ distinct sensitive values |
| **t-Closeness** (Li et al. 2007) | Skewness attack, where sensitive values cluster at one end | Distribution of sensitive values in each class must be within distance $t$ of the overall distribution |

Formally, let $E$ denote an equivalence class (a group of records sharing the same quasi-identifier values) and $S$ the sensitive attribute. $E$ satisfies **l-diversity** if

$$|\{s : \exists\, r \in E,\ r[S] = s\}| \geq l,$$

that is, $E$ contains at least $l$ distinct values of $S$. A dataset satisfies l-diversity if every equivalence class does.

$E$ satisfies **t-closeness** if

$$D(P_E, P_D) \leq t,$$

where $P_E$ is the distribution of $S$ within $E$, $P_D$ is its distribution across the whole dataset, and $D(\cdot, \cdot)$ is a distance measure between distributions (the original paper uses Earth Mover's Distance). A dataset satisfies t-closeness if every equivalence class does.

**Example**: suppose an equivalence class of five policyholders satisfies 5-anonymity, but all five happen to have made a fraud-flagged claim. An attacker who identifies someone as belonging to that group learns their claim history without ever picking out their specific record, a homogeneity attack. l-diversity would require that class to contain at least two distinct claim-outcome values before release. Now suppose the class does contain two values, but 90% of it is fraud-flagged claims against only 5% for the portfolio overall. That imbalance itself leaks information: membership in the group is now strong evidence of a fraud-flagged claim, even though the class is technically diverse. t-closeness would flag this class as too skewed relative to the overall distribution.

**Limitations of k-anonymity**:

- It provides no probabilistic guarantee. An attacker with additional background knowledge may still re-identify records.
- It operates on the released data, not on the query or analysis process.
- Generalisation reduces the granularity available for modelling and may introduce bias.

## Differential Privacy

**Why it was proposed.** k-Anonymity and its extensions reduce risk, but they only protect against re-identification within the specific released dataset, and provide no guarantee against an attacker who combines it with other information. In 2018, the US Census Bureau's own researchers demonstrated exactly this failure mode at scale: using only the aggregate statistical tables the Bureau had already published from the 2010 Census, combined with a commercially available marketing database, they reconstructed and re-identified demographic records for roughly one in six Americans, even though the underlying tables had been through the Bureau's standard disclosure-avoidance process (Abowd 2018). No single published table looked risky on its own. Combining enough of them was enough to break it. This "database reconstruction attack" led the Bureau to adopt differential privacy for the 2020 Census, still the largest real-world deployment of the technique. Dwork (Dwork et al. 2006) had proposed differential privacy over a decade earlier for exactly this class of problem: rather than trying to anticipate every way a released dataset might be combined with future outside information, provide a guarantee that holds regardless of what auxiliary information an attacker already has, by bounding what any single individual's own record can change about the output.

**Differential privacy** (DP) provides a mathematical guarantee about the *process* of releasing a statistic or model, rather than a property of the released dataset itself. It bounds the amount of information that any single individual's record can contribute to a published output.

**Definition.** A randomised mechanism $\mathcal{M}$ satisfies **$\varepsilon$-differential privacy** if, for all pairs of datasets $D$ and $D'$ that differ in exactly one record, and for all possible outputs $S$,

$$\Pr[\mathcal{M}(D) \in S] \leq e^{\varepsilon} \cdot \Pr[\mathcal{M}(D') \in S].$$

**In plain terms**: compare the mechanism's output distribution run on $D$ against the same mechanism run on $D'$, a dataset identical except that one person's record has been added, removed, or changed. The inequality says these two distributions can differ by at most a factor of $e^{\varepsilon}$, whichever single record is the one that changed. Someone looking only at the output cannot tell, beyond that factor, whether any particular individual's data was included at all, which is exactly the guarantee the Census reconstruction attack showed the Bureau's older methods did not provide: no amount of outside information can improve an attacker's odds by more than $e^{\varepsilon}$.

The parameter $\varepsilon \geq 0$ is the **privacy budget**. Smaller values provide stronger privacy guarantees, while larger values allow more accurate outputs.

**The Laplace mechanism** (adding a carefully calibrated amount of random noise to a number before releasing it) is the canonical method for privatising a numerical statistic. Given a function $f$ with **sensitivity** $\Delta f = \max_{D,D'} |f(D) - f(D')|$, the privatised release is

$$\mathcal{M}(D) = f(D) + \mathrm{Lap}\left(\frac{\Delta f}{\varepsilon}\right),$$

where $\mathrm{Lap}(\lambda)$ denotes a draw from a Laplace distribution with scale $\lambda$.

**In plain terms**: $\Delta f$ measures the worst-case swing that one person's record could cause in the true answer $f(D)$. For a sum of insurance claims, for example, that is the size of the single largest claim any one policyholder could contribute. The mechanism releases the true answer plus random noise scaled to that worst case and divided by the privacy budget: a smaller $\varepsilon$ (stronger privacy) means more noise is added, and a statistic with higher sensitivity needs more noise to reach the same $\varepsilon$.

**Example**: suppose the true average claim size for a group of policyholders is \$8,000, the largest claim any single policyholder could contribute is $\Delta f =$ \$2,000, and the privacy budget is $\varepsilon = 1$. The released statistic is \$8,000 plus a draw from Lap(2,000/1), which might come out as \$7,650 or \$9,400 depending on the random draw. Anyone using the released number cannot tell whether it equals the true average, or how far the noise pushed it in either direction.

**Interpreting** $\varepsilon$ (an illustrative rule of thumb, not a formal standard. The appropriate value depends on the sensitivity of the statistic and the acceptable accuracy loss):

| $\varepsilon$ | Interpretation |
|---|---|
| $\leq 1$ | Strong privacy, outputs may be quite noisy |
| 1–10 | Moderate privacy, commonly used in practice |
| $> 10$ | Weak privacy, output close to the true value |

**Key properties**:

- DP is composable. Applying $k$ mechanisms each with budget $\varepsilon_i$ consumes total budget $\sum_i \varepsilon_i$.
- DP is immune to post-processing. Any further computation on a DP output does not reduce privacy.
- DP is adopted by Apple, Google, the US Census Bureau, and is referenced in emerging AI regulation.

**Limitations**:

- Choosing $\varepsilon$ requires a policy judgement. There is no universal threshold.
- Noise calibrated to global sensitivity can be large when the statistic has high sensitivity (e.g., a sum over unbounded values).
- DP protects statistical releases. It does not directly protect against membership inference in machine learning models without additional techniques (e.g., DP-SGD).

## Synthetic Data

**Why it was proposed.** Statistical agencies have long faced the same tension covered in this section: researchers need record-level microdata to do useful analysis, but releasing real records, even with obvious identifiers removed, carries growing disclosure risk as more outside data becomes available to link against it (precisely the vulnerability k-anonymity and differential privacy each address in different ways). The US Internal Revenue Service's Statistics of Income (SOI) division has published a fully synthetic version of its individual income tax return public-use file since the early 2000s (Internal Revenue Service, Statistics of Income Division 2018), generated by fitting sequential regression models to the real, confidential returns, the same family of methods `synthpop` implements in Chapter 7. Rather than redacting or coarsening real taxpayer records, SOI generates entirely new, artificial returns whose statistical properties match the real population closely enough for tax-policy research, while containing no actual taxpayer's data at all.

**Synthetic data** is artificially generated data that mimics the statistical properties of a real dataset without containing any actual records. A generative model is fitted to the real data. New records are then sampled from that model.

**Example**: a synthetic version of the French motor insurance dataset used throughout this course might include a record for a "34-year-old policyholder in a mid-density postcode with a Bonus level of 20 and no claims history," generated from the fitted model's learned relationships between age, density, bonus level, and claims. No real policyholder needs to match that combination for the record to be useful, and no real policyholder's actual data is disclosed by releasing it. Chapter 7 generates exactly this kind of data from the same dataset.

**Two core objectives** must be balanced:

- **Fidelity** (utility): the synthetic data should preserve the statistical relationships, such as marginal distributions, correlations, and model performance, needed for the intended downstream use.
- **Privacy**: the synthetic data should not allow an attacker to infer sensitive information about individuals in the original dataset.

**Common generation approaches**:

| Approach | Example tools | Typical use |
|---|---|---|
| Sequential regression models | `synthpop` (R) | Tabular survey, health, or actuarial data |
| Bayesian networks | `DataSynthesizer` | Mixed-type datasets with dependencies |
| Generative adversarial networks (GANs) | `CTGAN`, `SDV` | High-dimensional tabular or image data |
| Variational autoencoders (VAEs) | `TVAE` | Continuous data |

**Evaluating synthetic data**:

- *Marginal fidelity*: do synthetic distributions match real distributions variable by variable?
- *Joint fidelity*: are pairwise and higher-order relationships preserved?
- *Model performance*: does a model trained on synthetic data perform similarly when applied to real data?
- *Privacy risk*: do synthetic records closely resemble real records? Nearest-neighbour distance ratios (NNDR) are a common diagnostic.

**Key limitation**: synthetic data does not automatically guarantee privacy. Memorisation by the generative model can cause it to reproduce individual real records, particularly for rare or extreme observations. Without explicit privacy accounting (e.g., DP during training), synthetic data provides no formal privacy guarantee.

## Federated Learning: a different approach

**Why it was proposed.** Google introduced federated learning in 2017 to solve a concrete engineering problem: improving next-word predictions on its Gboard mobile keyboard (McMahan et al. 2017). The text people type, including passwords, search queries, and personal messages, is exactly the data a better prediction model needs to learn from, and exactly the data users do not want uploaded to a central server. Sending every keystroke from

hundreds of millions of phones to Google's servers would also have been enormously bandwidth-intensive. McMahan et al.'s solution kept the raw text on the device entirely: each phone trains the shared model locally on its own typing history, and only the resulting model update, a set of numbers describing how the model changed, not the text itself, is sent back and averaged across devices (the FederatedAveraging algorithm). The same architecture generalises directly to any setting where the data is sensitive and already scattered across separate holders, exactly the insurance and banking case discussed below.

The three techniques above all start from a different premise: data is collected in one place, then anonymised, perturbed, or synthesised before release or analysis. **Federated learning** takes a different route: the raw data never leaves the device or organisation that holds it.

A central server sends a shared model to each participant (e.g., a hospital, an insurer, a mobile device). Each participant trains the model locally on its own data, then sends back only the updated model parameters (weights, not records) to be aggregated into an improved shared model. The raw data is never centralised or transmitted.

**Example**: three insurers wanting to jointly flag suspicious claims patterns would each keep their own claims database in-house. Each trains the shared fraud-detection model overnight on its own claims, and sends back only the updated model weights, never an individual claim record, to be averaged into next day's shared model. None of the three insurers ever sees another's raw policyholder data, only the model that results from all three having trained on it.

This addresses a limitation shared by all three techniques above: each assumes the data can be centralised somewhere, even briefly, before protection is applied.

> **i** Case Study: WeBank's FATE, a real production deployment
>
> WeBank, a Chinese digital bank founded by Tencent, developed **FATE** (Federated AI Technology Enabler) (Liu et al. 2021), an open-source federated learning platform it donated to the Linux Foundation in 2019. WeBank used it to build a federated credit-rating model, and has since led China's national standardisation effort for federated machine learning. Several Chinese financial institutions now use FATE or similar frameworks to collaborate on credit and risk models without pooling raw customer data.
> A directly analogous insurance use case, several insurers jointly training a shared fraud-detection model across their claims histories without any party seeing another's raw policyholder data, remains largely at the research and pilot stage. Published results in this space are mostly from simulated multi-party experiments rather than documented production deployments the way WeBank's credit-rating use case is.

**Limitations**:

- Model updates can still leak information about the training data (e.g., through gradient inversion attacks), so federated learning is often combined with differential privacy (adding noise to the aggregated updates) or secure aggregation (a cryptographic protocol ensuring the server only sees the sum of updates, not any individual participant's contribution).
- Coordinating training across participants with different data distributions, infrastructure, and availability is operationally harder than centralised training.
- It protects data *location*, not data *content*: a sufficiently determined attacker with access to the shared model may still be able to infer information about the training data, the same class of risk covered under re-identification and membership inference above.

Related distributed-computation techniques include **homomorphic encryption** (computing directly on encrypted data) and **secure multi-party computation** (multiple parties jointly compute a function over their combined data without revealing their individual inputs to each other). Both are more computationally expensive than federated learning and remain largely at the research or pilot stage for the data volumes typical of insurance applications.

## Choosing a Technique

The three families of techniques above serve different purposes and are suited to different data sharing contexts. Federated learning answers a different question, whether data needs to be centralised at all, so it does not compete with the other three on the same terms. It is included below for comparison, not as a fourth interchangeable option.

| Technique | Formal guarantee | Preserves record structure | Suitable for modelling | Regulatory recognition |
|---|---|---|---|---|
| k-Anonymity | No | Yes (generalised) | Reduced utility | GDPR recital 26 |
| Differential privacy | Yes ($\varepsilon$-DP) | No (adds noise) | Statistics and ML | US Census, emerging EU/AU guidance |
| Synthetic data | No (unless DP-trained) | No (new records) | Yes (if high fidelity) | Growing acceptance, no formal standard |
| Federated learning | No (unless combined with DP) | N/A, no data is released | Yes, by design | Growing, e.g. China's national federated-learning standard, no comprehensive framework yet |

In practice these techniques are often **combined**. K-anonymity or suppression may be applied before synthetic data generation to reduce memorisation risk, and differential privacy may be used during model training to bound the influence of individual records. The first three do not change *where* the data is processed, each still assumes it is centralised, even briefly, before protection is applied. Federated learning addresses that different question directly, at the cost of the operational and residual-leakage limitations noted above.

Chapter 7 applies each of the three data-release techniques to the French motor insurance dataset and examines the quantitative trade-off between privacy protection and statistical utility.

# Privacy principles in practice

## Data Protection Impact Assessment (DPIA / PIA)

A **Privacy Impact Assessment** (PIA in Australian terminology, DPIA under GDPR) is a structured process for identifying and managing privacy risks before deploying a new data system or practice.

**When required**: GDPR Art 35 mandates a DPIA for large-scale processing of sensitive data, systematic profiling, and processing that is "likely to result in a high risk", which describes many AI applications in insurance, healthcare, hiring, and lending.

**A simplified four-stage summary** of the OAIC's (Australia's privacy regulator) more detailed 10-step PIA process (Office of the Australian Information Commissioner 2021):

| Step | Activity |
|---|---|
| **1. Identify** | Map data flows: what is collected, from whom, for what purpose, who has access |
| **2. Assess** | Identify privacy risks against APP obligations and community expectations |
| **3. Recommend** | Propose controls to eliminate or reduce risks |
| **4. Respond** | Implement recommendations and document residual risks |

**Applied to a new product**: suppose an insurer is about to launch a usage-based insurance (UBI) telematics app.

- **Identify**: the data flow map would show GPS pings every few seconds, braking and acceleration events, and speed, flowing from the customer's phone or a plug-in device, through the vendor's platform, to the insurer's pricing engine, and potentially on to any third party the vendor's contract allows.
- **Assess**: continuous location data reveals home and work addresses even though the stated purpose is only pricing, and the same pattern behind the GM OnStar case, data quietly reaching a third party beyond the original purpose, is a live risk wherever a vendor sits between the customer and the insurer.
- **Recommend**: collect trip-level summaries (aggregated speed/braking statistics) rather than raw GPS traces where the pricing model doesn't need them, write a purpose-limitation clause into the vendor contract barring resale, and apply k-anonymity or aggregation before sharing any data externally.

- **Respond**: document that driving patterns remain inferable from even summarised data as a residual risk, and get sign-off from whoever is accountable for that risk before launch.

This is exactly the assessment GM's own DPIA process should have caught before OnStar Smart Driver launched.

## Privacy considerations for large language models

The techniques above (anonymisation, differential privacy, synthetic data) were developed for structured, tabular datasets with a known schema. Large language models (LLMs) introduce a privacy failure mode those techniques weren't built for. The model itself, trained on billions of documents scraped from the web, can memorise and later regurgitate verbatim fragments of its training data.

**Memorisation and extraction.** Carlini et al. (2021) show that LLMs memorise some training examples exactly, and that an attacker who only has query access to the model, not access to the training data itself, can extract these memorised fragments, including personal information that happened to appear in the training corpus. Nasr et al. (2023) extend this to production, safety-aligned chatbots. A simple prompting attack caused a deployed chatbot to emit memorised training text, including real personal data, at a much higher rate than during normal use. This is a fundamentally different threat model from the re-identification risk discussed above. There is no dataset being released for an attacker to re-identify. The *model* is the leak.

**A real breach, not just a research finding.** A March 2023 bug in ChatGPT's Redis library briefly exposed some users' chat titles to other users, and exposed the names, email addresses, billing addresses, and partial payment-card details (last four digits and expiry date, not the full number) of about 1.2% of ChatGPT Plus subscribers active during a nine-hour window (OpenAI 2023). This was not a memorisation attack of the kind described above. It was a conventional software bug, but it shows the same underlying point: an LLM product is a live system handling personal data, not just a static model, and it can fail the same ways any other system can.

**Regulatory response.** Weeks later, Italy's data protection authority ordered a temporary halt to ChatGPT's processing of Italian users' data, citing this incident alongside an absence of a valid legal basis for processing and a lack of transparency about training-data sources (Garante per la protezione dei dati personali 2023), an early, concrete precedent for applying GDPR-style lawfulness and transparency principles to a foundation model rather than a conventional database.

**Practical implication.** Two distinct privacy questions arise whenever an LLM is used in a consequential workflow: (1) *could the model itself leak something it was trained on* (a concern for whoever trained or fine-tuned it), and (2) *what happens to the data in this prompt* (a concern for whoever is calling a third-party LLM API). The second is the more immediate risk for most organisations. Sending a customer's claim details, medical history, or identifying information into a prompt raises the same purpose-limitation and data-minimisation questions as any third-party data sharing, and depends entirely on that provider's data-retention and training-use terms. Samsung learned this directly: in three separate incidents within three weeks in 2023, engineers pasted proprietary source code, a transcribed internal meeting, and confidential test data into ChatGPT to get help with their own work, after which the company banned the tool for staff entirely (Ray 2023). The DPIA process above should treat an LLM API call as a data disclosure, not just a computation.

## Summary: the core privacy principles

| Principle | Legal basis | Practical meaning for AI systems |
|---|---|---|
| **Lawfulness** | GDPR Art 5, APP 3 | Identify legal basis before collecting or processing data |
| **Purpose limitation** | GDPR Art 5, APP 6 | Data collected for one purpose (e.g. underwriting, screening) cannot be freely repurposed for another (e.g. marketing) |
| **Data minimisation** | GDPR Art 5, APP 3 | Collect only variables needed, and do not retain "just in case" |
| **Transparency** | GDPR Art 5, APP 1/5 | Explain what data is used and how, in plain language |
| **Accuracy** | GDPR Art 5, APP 10 | Verify data quality, allow correction |
| **Security** | GDPR Art 5, APP 11 | Technical and organisational controls |
| **Accountability** | GDPR Art 5 | Document decisions, and be able to demonstrate compliance |

## Recommended reading

- Solove (2006), taxonomy of privacy violations, foundational conceptual framework
- Nissenbaum (2004), contextual integrity, best framework for analysing data reuse
- (Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation) 2016), GDPR Articles 5, 6, 22, 25, 35
- Court of Justice of the European Union (2023); Court of Justice of the European Union (2025), CJEU rulings clarifying the scope of Article 22 and the Article 15(1)(h) access right
- Office of the Australian Information Commissioner (2023), Australian Privacy Principles (free, oaic.gov.au)
- Boucher and Turcotte (2020), privacy tensions in usage-based insurance
- Carlini et al. (2021); Nasr et al. (2023), memorisation and training-data extraction attacks specific to large language models


Abowd, John M. 2018. "The u.s. Census Bureau Adopts Differential Privacy." *Proceedings of the 24th ACM SIGKDD International Conference on Knowledge Discovery & Data Mining*, 2867.

Bednarz, Zofia et al. 2025. ""It's Not Personal, It's Strictly Business": Behavioural Insurance and the Impacts of Non-Personal Data on Individuals, Groups and Societies." *Computer Law & Security Review* 56: 106096. https://doi.org/10.1016/j.clsr.2024.106096.

Boucher, Jean-Philippe, and Roxane Turcotte. 2020. "Telematics and the Automobile Insurance Industry." *Variance* 13 (2): 192–211.

California Privacy Protection Agency. 2023. *California Privacy Rights Act (Amending the California Consumer Privacy Act)*. https://cppa.ca.gov/regulations/consumer_privacy_act.html.

Carlini, Nicholas, Florian Tramèr, Eric Wallace, et al. 2021. "Extracting Training Data from Large Language Models." *30th USENIX Security Symposium*, 2633–50.

Cavoukian, Ann. 2009. *Privacy by Design: The 7 Foundational Principles*. Information; Privacy Commissioner of Ontario, Canada. https://ipc.on.ca/en/media/1183/download?attachment=.

China Banking and Insurance Regulatory Commission. 2022. *Measures for the Administration of Consumer Rights Protection by Banking and Insurance Institutions, Article 27 ( , )*. https://www.nfra.gov.cn/cn/view/pages/ItemDetail.html?docId=1087524&generaltype=0&itemId=4098.

Court of Justice of the European Union. 2023. *Judgment of the Court (First Chamber), OQ v Land Hessen, Joined Party SCHUFA Holding AG, Case c-634/21*. https://curia.europa.eu/juris/liste.jsf?num=C-634/21.

Court of Justice of the European Union. 2025. *Judgment of the Court (First Chamber), CK v Magistrat Der Stadt Wien, Joined Party Dun & Bradstreet Austria GmbH, Case c-203/22*. https://curia.europa.eu/juris/liste.jsf?num=C-203/22.

Dwork, Cynthia, Frank McSherry, Kobbi Nissim, and Adam Smith. 2006. "Calibrating Noise to Sensitivity in Private Data Analysis." *Proceedings of the Third Theory of Cryptography Conference*, 265–84.

Federal Trade Commission. 2026. "FTC Finalizes Order Settling Allegations That GM and OnStar Collected and Sold Geolocation Data Without Consumers' Informed Consent." https://www.ftc.gov/news-events/news/press-releases/2026/01/ftc-finalizes-order-settling-allegations-gm-onstar-collected-sold-geolocation-data-without-consumers.

Garante per la protezione dei dati personali. 2023. *Provvedimento Del 30 Marzo 2023 [9870832]: Limitazione Provvisoria Del Trattamento Dei Dati Di ChatGPT*. https://www.garanteprivacy.it/home/docweb/-/docweb-display/docweb/9870832.

Huang, Fei. 2026. "Insurers Have a Lot of Data about Us. Where Do They Get It, and How Do They Use It?" The Conversation, August. https://theconversation.com/insurers-have-a-lot-of-data-about-us-where-do-they-get-it-and-how-do-they-use-it-290053.

Internal Revenue Service, Statistics of Income Division. 2018. *Creating Homogeneous Synthetic Individual Tax Files for Public Use*. Internal Revenue Service. https://www.irs.gov/pub/irs-soi/18rpsynthindtaxfiles.pdf.

Li, Ninghui, Tiancheng Li, and Suresh Venkatasubramanian. 2007. "T-Closeness: Privacy Beyond k-Anonymity and l-Diversity." *Proceedings of the 23rd IEEE International Conference on Data Engineering*, 106–15.

Liu, Yang, Tao Fan, Tianjian Chen, Qian Xu, and Qiang Yang. 2021. "FATE: An Industrial Grade Platform for Collaborative Learning with Data Protection." *Journal of Machine Learning Research* 22 (226): 1–6.

Machanavajjhala, Ashwin, Daniel Kifer, Johannes Gehrke, and Muthuramakrishnan Venkitasubramaniam. 2007. "$\ell$-Diversity: Privacy Beyond k-Anonymity." *ACM Transactions on Knowledge Discovery from Data* 1: 3.

McMahan, Brendan, Eider Moore, Daniel Ramage, Seth Hampson, and Blaise Aguera y Arcas. 2017. "Communication-Efficient Learning of Deep Networks from Decentralized Data." *Artificial Intelligence and Statistics*, 1273–82.

Merrill, Jeremy B, and Talia Gillis. 2024. "How GM Tracked Millions of Drivers and Sold Their Data Without Clear Consent." *The New York Times / The Markup*. https://themarkup.org/privacy/2024/03/11/gm-connected-vehicle-data-onstar-lexisnexis-insurance.

Mozilla Foundation. 2023. *It's Official: Cars Are the Worst Product Category We Have Ever Reviewed for Privacy*. Privacy Not Included Research Report. Mozilla Foundation. https://foundation.mozilla.org/en/privacynotincluded/articles/its-official-cars-are-the-worst-product-category-we-have-ever-reviewed-for-privacy/.

Narayanan, Arvind, and Vitaly Shmatikov. 2008. "Robust de-Anonymization of Large Sparse Datasets." *Proceedings of the 2008 IEEE Symposium on Security and Privacy*, 111–25. https://doi.org/10.1109/SP.2008.33.

Nasr, Milad, Nicholas Carlini, Jonathan Hayase, et al. 2023. "Scalable Extraction of Training Data from (Production) Language Models." *arXiv Preprint arXiv:2311.17035*.

National Financial Regulatory Administration (China). 2026. *Guidance on the Safe Development and Application of Artificial Intelligence in the Banking and Insurance Sectors ( , Jin Fa [2026] No. 8)*. https://www.nfra.gov.cn/cn/view/pages/governmentDetail.html?docId=1261784&generaltype=1.

National People's Congress (China). 2021. *Personal Information Protection Law of the People's Republic of China ( )*. http://www.npc.gov.cn/npc/c2/c30834/202108/t20210820_313088.html.

Nissenbaum, Helen. 2004. "Privacy as Contextual Integrity." *Washington Law Review* 79 (1): 119–57.

Office of the Australian Information Commissioner. 2021. "10 Steps to Undertaking a Privacy Impact Assessment." https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/privacy-impact-assessments/10-steps-to-undertaking-a-privacy-impact-assessment.

Office of the Australian Information Commissioner. 2023. "Australian Privacy Principles." https://www.oaic.gov.au/privacy/australian-privacy-principles.

OpenAI. 2023. "March 20 ChatGPT Outage: Here's What Happened." March. https://openai.com/index/march-20-chatgpt-outage/.

Personal Data Protection Commission Singapore. 2012. *Personal Data Protection Act 2012*. https://www.pdpc.gov.sg/overview-of-pdpa/the-legislation/personal-data-protection-act.

Privacy and Other Legislation Amendment Act 2024 (Cth) (2024).

Ray, Siladitya. 2023. "Samsung Bans ChatGPT Among Employees After Sensitive Code Leak." Forbes, May. https://www.forbes.com/sites/siladityaray/2023/05/02/samsung-bans-chatgpt-and-other-chatbots-for-

employees-after-sensitive-code-leak/.

Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation) (2016).

Regulation (EU) 2023/2854 of the European Parliament and of the Council on Harmonised Rules on Fair Access to and Use of Data (Data Act) (2023).

Solove, Daniel J. 2006. "A Taxonomy of Privacy." *University of Pennsylvania Law Review* 154 (3): 477–564.

Sweeney, Latanya. 2000. *Simple Demographics Often Identify People Uniquely.* Data Privacy Working Paper 3. Carnegie Mellon University.

Sweeney, Latanya. 2002. "K-Anonymity: A Model for Protecting Privacy." *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems* 10 (5): 557–70.

Wachter, Sandra. 2020. "Affinity Profiling and Discrimination by Association in Online Behavioural Advertising." *Berkeley Technology Law Journal* 35 (2): 369–430.

Westin, Alan F. 1967. *Privacy and Freedom.* Atheneum.